

RIESGOS DE EXFILTRACIÓN DE DATOS EN SISTEMAS RAG Y MODELOS DE LENGUAJE

Informe de investigación basado en evidencia estadística verificable

Enfoque exclusivo: exfiltración de datos en arquitecturas de Retrieval-Augmented Generation (RAG)

— con gráficas, tabla de probabilidades de éxito de ataque y fuentes primarias enlazadas —

Septiembre de 2026

1. Introducción y alcance

Este informe se enfoca exclusivamente en los riesgos de seguridad que enfrentan los sistemas de Generación Aumentada por Recuperación (RAG) y los modelos de lenguaje (LLM) frente a la exfiltración de datos — el tema central del proyecto rag-exfiltration-security. Cada problema documentado conecta directamente con uno de los mecanismos que el proyecto demuestra: ausencia de filtrado por rol/clasificación en la recuperación, inyección de instrucciones para forzar al modelo a revelar contexto privado, y falta de gobernanza sobre qué puede ver un sistema de IA.

A diferencia de una encuesta de opinión, la evidencia más fuerte de este informe proviene de un estudio académico experimental (Qi et al., 2024, Harvard/CMU/MBZUAI) que ataca sistemas RAG reales y mide con precisión qué fracción del contenido privado logra extraerse — el equivalente exacto, a escala de laboratorio, de lo que el Ataque 3 ("inyección de instrucciones") del proyecto rag-exfiltration-backend busca demostrar de forma didáctica.

Se incluye una tabla de probabilidades de éxito de ataque (sección 3) que reúne, en un solo lugar, todas las tasas de éxito, extracción o exposición medidas por las fuentes citadas. Todos los enlaces de este documento son hipervínculos activos: al hacer clic sobre cualquier URL en las tablas de fuentes o en la bibliografía, se abre la página original correspondiente.

2. Los siete problemas, con evidencia detallada

2.1 Inyección de instrucciones (prompt injection) como vector #1 de exfiltración en sistemas RAG/LLM

Problema o riesgo	La inyección de instrucciones (prompt injection) —directa o indirecta— es el mecanismo dominante para exfiltrar datos de un sistema basado en LLM, incluyendo sistemas RAG.
Descripción	Un atacante incrusta instrucciones dentro de la consulta o dentro de un documento que el sistema recupera, y el modelo las ejecuta como si fueran parte de su instrucción legítima, revelando contenido que debía permanecer privado (el mismo patrón que el ataque 3 del proyecto rag-exfiltration-backend).
Estadística principal	OWASP clasifica la inyección de instrucciones (LLM01:2025) como el riesgo #1 de seguridad para aplicaciones LLM por segunda edición consecutiva (2024 y 2025). En un estudio académico controlado, investigadores de Harvard, Carnegie Mellon y MBZUAI lograron una tasa de éxito del 100% al extraer el contenido privado ("datastore") de 25 GPTs personalizados mediante inyección de instrucciones, usando como máximo 2 consultas por sistema.
Empresas / sistemas afectados	25 aplicaciones RAG de producción (GPTs personalizados de OpenAI) de dominios sensibles: ciberseguridad, derecho, finanzas, medicina y religión; además, 9 modelos de lenguaje open-source ampliamente usados (Llama2, Mistral, Mixtral, Vicuna, SOLAR, WizardLM, Qwen1.5, Platypus2).
Impacto medible	Con solo 100 consultas auto-generadas por el propio sistema atacado, los investigadores reconstruyeron el 41,73% del texto verbatim de un libro de 77.000 palabras y el 3,22% de un corpus de Wikipedia de 1.569.000 palabras. La vulnerabilidad se agrava a medida que el modelo es más grande y más capaz de seguir instrucciones.
Sectores / dominios afectados	Ciberseguridad, derecho, finanzas, medicina y religión (los 5 dominios de los 25 GPTs atacados en el estudio); el riesgo es transversal a cualquier RAG empresarial, incluyendo el dominio académico/universitario del proyecto de origen.

Quién reporta el problema	OWASP GenAI Security Project (marco de clasificación de riesgos, sin fines comerciales); Qi, Zhang, Xing, Kakade y Lakkaraju — Universidad de Harvard, Carnegie Mellon University y Mohamed bin Zayed University of AI (estudio académico revisado por pares, sin patrocinio comercial).
Metodología	Estudio experimental controlado: los autores construyeron sistemas RAG con 9 LLM open-source distintos y atacaron 25 sistemas RAG de producción reales (GPTs), midiendo la tasa de éxito del ataque y la "tasa de reconstrucción" (proporción del texto original recuperado) con métricas estandarizadas (ROUGE-L, BLEU, F1, BERTScore).
Año de los datos	2024 (paper publicado en febrero de 2024, revisado y actualizado en octubre de 2024).
País / región	No aplica geografía específica — estudio de laboratorio con sistemas de producción globales (OpenAI GPTs).
Fuente original	Qi, Z., Zhang, H., Xing, E., Kakade, S., & Lakkaraju, H. (2024). "Follow My Instruction and Spill the Beans: Scalable Data Extraction from Retrieval-Augmented Generation Systems".
Enlace a la fuente	https://arxiv.org/abs/2402.17840
Referencia bibliográfica completa	Qi, Z., Zhang, H., Xing, E., Kakade, S., & Lakkaraju, H. (2024). Follow My Instruction and Spill the Beans: Scalable Data Extraction from Retrieval-Augmented Generation Systems. arXiv:2402.17840.
Limitaciones o sesgos	Es un estudio de laboratorio/prueba de concepto, no una encuesta sobre la incidencia real de estos ataques en producción a nivel de mercado; los propios autores señalan que su intención es alertar a la comunidad, no proveer una estadística de prevalencia poblacional. Los 25 GPTs atacados fueron seleccionados por los investigadores, no muestreados aleatoriamente del GPT Store completo, lo que limita la generalización estadística estricta.

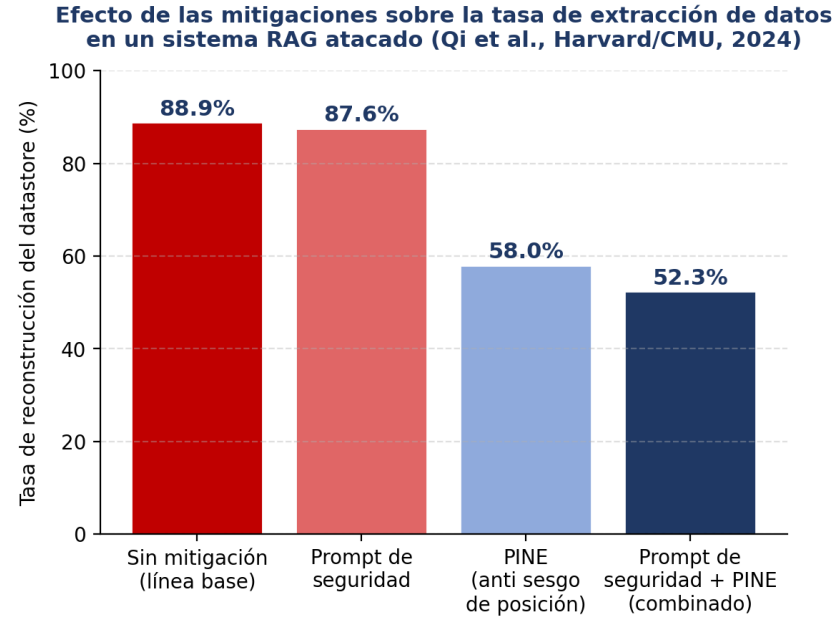


Figura 1. Tasa de reconstrucción del contenido privado de un RAG según la mitigación aplicada. Fuente: Qi et al. (2024).

2.2 La exfiltración escala con el tamaño del corpus y el número de consultas

Problema o riesgo	La cantidad de información que un atacante puede extraer de un sistema RAG crece de forma medible con el número de consultas realizadas, incluso sin acceso privilegiado al sistema (ataque de caja negra).
Descripción	A diferencia de una brecha de datos tradicional (todo o nada), la exfiltración de un RAG es incremental: cada consulta bien diseñada reconstruye un fragmento adicional del "datastore" privado, por lo que el riesgo depende directamente de cuántas consultas puede hacer el atacante antes de ser detectado.
Estadística principal	Con 100 consultas generadas por el propio sistema, los atacantes reconstruyeron el 41,73% de un corpus pequeño (77.000 palabras) frente a solo el 3,22% de un corpus grande (1.569.000 palabras) — es decir, la fracción extraíble es mayor cuanto más acotado es el corpus, un dato directamente relevante para el corpus reducido (5 documentos) usado en el proyecto rag-exfiltration-backend.
Empresas / sistemas afectados	Sistemas RAG construidos con la técnica estándar "Retrieval-In-Context" (RIC), el patrón de implementación más común y el mismo que usa LangChain4j en el proyecto rag-exfiltration-backend.
Impacto medible	La tasa de reconstrucción aumenta de forma monótona con: (a) el número de consultas, (b) el tamaño de los fragmentos recuperados por consulta (chunk size) y (c) el número de fragmentos por consulta (top-k) — los tres parámetros que cualquier equipo de RAG configura directamente.
Sectores / dominios afectados	Cualquier RAG empresarial con corpus de tamaño pequeño o mediano (bases de conocimiento internas, wikis corporativas, repositorios legales o médicos) es proporcionalmente más vulnerable que uno con corpus masivo.
Quién reporta el problema	Qi, Zhang, Xing, Kakade y Lakkaraju — Universidad de Harvard, Carnegie Mellon University y Mohamed bin Zayed University of AI.
Metodología	Experimento controlado variando sistemáticamente el número de consultas (hasta 100), el número de fragmentos recuperados por consulta (1, 2, 4, 8) y la longitud máxima de cada fragmento (27 a 212 tokens), midiendo la "longitud de reconstrucción absoluta" en caracteres.
Año de los datos	2024.
País / región	No aplica — estudio de laboratorio.
Fuente original	Qi, Z., Zhang, H., Xing, E., Kakade, S., & Lakkaraju, H. (2024). "Follow My Instruction and Spill the Beans...".
Enlace a la fuente	https://arxiv.org/abs/2402.17840
Referencia bibliográfica completa	Qi, Z., Zhang, H., Xing, E., Kakade, S., & Lakkaraju, H. (2024). Follow My Instruction and Spill the Beans: Scalable Data Extraction from Retrieval-Augmented Generation Systems. arXiv:2402.17840.
Limitaciones o sesgos	Los resultados provienen de un solo estudio (aunque con múltiples modelos y configuraciones); no existe todavía una réplica independiente publicada que confirme las cifras exactas de porcentaje de extracción en corpus corporativos reales fuera del entorno de laboratorio.

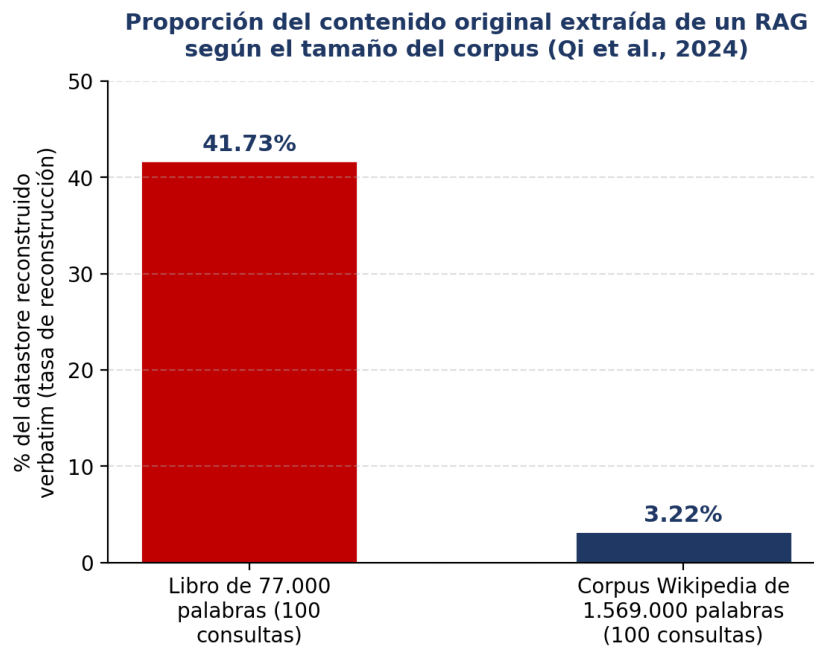


Figura 2. Porcentaje del corpus reconstruido verbatim según su tamaño, con 100 consultas. Fuente: Qi et al. (2024).

2.3 Brechas de datos vinculadas a IA generativa y falta de controles de acceso

Problema o riesgo	Un subconjunto creciente y medible de las brechas de datos empresariales ya involucra directamente modelos o aplicaciones de IA generativa, y casi todas ocurren por ausencia de controles de acceso — el mismo patrón de vulnerabilidad de raíz que ilustra el proyecto rag-exfiltration-backend (ausencia de filtrado por rol/clasificación).
Descripción	Incidentes en los que el vector de compromiso o el activo comprometido es un modelo de IA, una aplicación construida sobre un LLM, o un flujo de datos hacia una herramienta de IA no gobernada.
Estadística principal	13% de las organizaciones encuestadas reportó una brecha de sus modelos o aplicaciones de IA en el último año; de esas organizaciones comprometidas, 97% no contaba con controles de acceso adecuados para sus sistemas de IA. Las brechas vinculadas a "shadow AI" (IA no autorizada) representan ya el 20% de todas las brechas registradas y añaden en promedio USD 670.000 de costo adicional por incidente.
Empresas afectadas / muestra	600 organizaciones que sufrieron una brecha de datos confirmada entre marzo de 2024 y febrero de 2025, en 16 sectores industriales y 17 países.
Impacto económico / empresarial	El 60% de los incidentes de seguridad relacionados con IA derivó en compromiso de datos y el 31% en interrupción operativa; las brechas ligadas a shadow AI afectaron desproporcionadamente datos de identificación personal de clientes (65% vs. 53% del promedio global) y propiedad intelectual (40% vs. 33% del promedio global).
Sectores / industrias afectadas	Transversal a todos los sectores estudiados; especialmente relevante en organizaciones que han desplegado copilotos, chatbots o sistemas RAG internos sin gobernanza formal.
Quién reporta el problema	IBM Security, en colaboración con el Instituto Ponemon (investigación independiente encargada por IBM).
Metodología	Entrevistas y análisis de costos reales en 600 organizaciones que confirmaron haber sufrido una brecha, con un módulo específico de la encuesta 2025 dedicado por primera vez a incidentes de seguridad y gobernanza de IA.

Año de los datos	2025 (periodo de recolección: marzo 2024 – febrero 2025).
País / región	Global — 17 países.
Fuente original	IBM Security / Ponemon Institute — "Cost of a Data Breach Report 2025".
Enlace a la fuente	https://www.ibm.com/reports/data-breach
Referencia bibliográfica completa	IBM Security & Ponemon Institute. (2025). Cost of a Data Breach Report 2025. IBM Corporation. Armonk, NY, Estados Unidos.
Limitaciones o sesgos	La muestra son organizaciones que YA sufrieron una brecha, no una muestra aleatoria de todas las empresas que usan IA; mide severidad condicional a la ocurrencia del incidente, no la probabilidad de que cualquier empresa con IA sufra uno. Es un estudio patrocinado por un proveedor de ciberseguridad (IBM), lo que puede introducir sesgo hacia narrativas que favorecen sus propias herramientas de gobernanza de IA.

Brechas de datos empresariales vinculadas a IA no autorizada ("shadow AI") — IBM, 2025

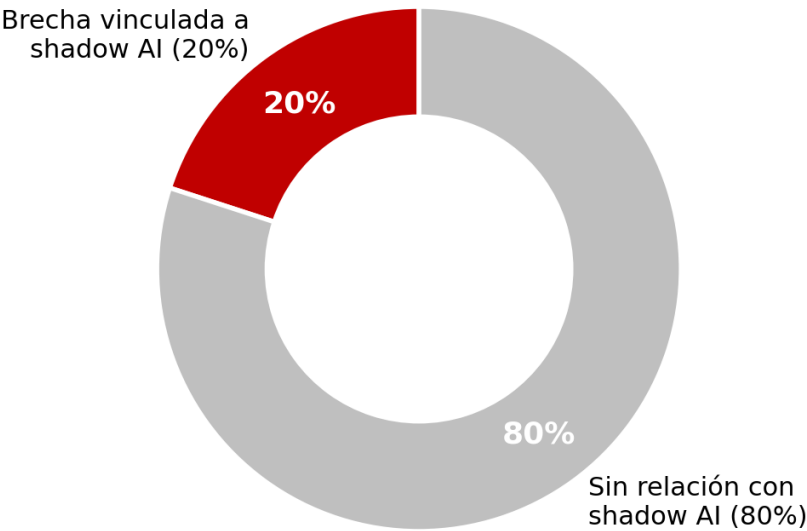


Figura 3. Proporción de brechas de datos empresariales vinculadas a IA no autorizada. Fuente: IBM (2025).

2.4 Ausencia de gobernanza y políticas de seguridad para sistemas de IA

Problema o riesgo	La mayoría de las organizaciones despliega o permite el uso de IA generativa sin políticas formales de gobernanza, control de acceso o clasificación de datos — exactamente el vacío que el Avance 1 del proyecto rag-exfiltration-backend documenta de forma deliberada como "riesgo inherente".
Descripción	Ausencia de reglas, procesos o controles técnicos que definan qué datos puede ver un sistema de IA, quién puede consultarlo y cómo se audita su uso.
Estadística principal	63% de las organizaciones no cuenta con políticas de gobernanza para gestionar la IA o prevenir riesgos de "shadow AI" (IBM, 2025). En una encuesta separada, solo 18% de las empresas tiene una política formal de seguridad de IA (Salesforce Workforce AI Survey,

	2026), y apenas 12% de las organizaciones puede nombrar todas las herramientas de IA en uso dentro de la empresa (Gartner AI Governance Survey, 2026).
Empresas afectadas / muestra	600 organizaciones encuestadas por IBM/Ponemon (2025); encuestas independientes adicionales de Salesforce y Gartner en 2026 confirman cifras del mismo orden de magnitud con metodologías distintas.
Impacto económico / empresarial	Gartner proyecta que, para 2027, más del 40% de las brechas de datos relacionadas con IA se originará en el uso indebido de IA generativa a través de fronteras (transferencias internacionales de datos sin supervisión), un problema de gobernanza, no técnico.
Sectores / industrias afectadas	Transversal; las organizaciones con integraciones de IA generativa embebidas en productos existentes (sin anuncio ni descripción clara al usuario) son las más expuestas según Gartner.
Quién reporta el problema	IBM Security/Ponemon Institute; Gartner, Inc. (firma de investigación y asesoría, sin producto de ciberseguridad propio que vender — menor conflicto de interés que un proveedor); Salesforce (empresa de software con interés comercial en IA empresarial gobernada).
Metodología	IBM: encuesta a 600 organizaciones afectadas por brechas (ver problema 3). Gartner: informe de predicción "Predicts 2025: Privacy in the Age of AI and the Dawn of Quantum", basado en análisis de tendencias regulatorias y entrevistas con clientes empresariales de Gartner.
Año de los datos	2025 (IBM) y proyección a 2027 (Gartner, publicada en febrero de 2025).
País / región	Global.
Fuente original	Gartner, Inc. — "Gartner Predicts 40% of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027".
Enlace a la fuente	https://www.gartner.com/en/newsroom/press-releases/2025-02-17-gartner-predicts-forty-percent-of-ai-data-breaches-will-arise-from-cross-border-genai-misuse-by-2027
Referencia bibliográfica completa	Gartner, Inc. (2025). Gartner Predicts 40% of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027 [comunicado de prensa]. Stamford, CT, Estados Unidos: Gartner, Inc. IBM Security & Ponemon Institute. (2025). Cost of a Data Breach Report 2025.
Limitaciones o sesgos	La cifra de Gartner ("40% para 2027") es una proyección/predicción de analista, no una medición retrospectiva; debe tratarse como una estimación experta, no un hecho consumado. Las cifras de Salesforce y Gartner sobre políticas formales (18%, 12%) provienen de encuestas con metodologías y tamaños de muestra no siempre publicados con el mismo detalle que el estudio de IBM, lo que limita la comparabilidad exacta entre ellas.

Organizaciones sin política de gobernanza de IA
(IBM Cost of a Data Breach Report, 2025)

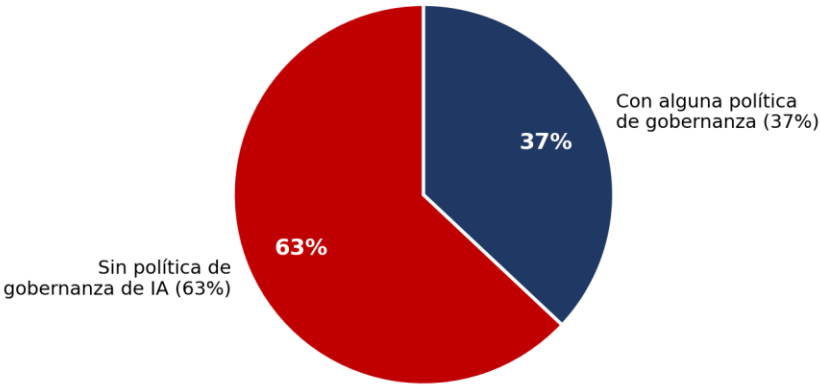


Figura 4. Organizaciones sin política de gobernanza de IA. Fuente: IBM (2025).

2.5 Fuga de datos sensibles por empleados hacia herramientas de IA no gobernadas (shadow AI)

Problema o riesgo	Los propios empleados exponen datos corporativos sensibles al pegarlos o subirlos a herramientas de IA generativa fuera del control de la organización, un canal de exfiltración que no requiere ningún ataque técnico — solo la ausencia de la política de control de acceso que el proyecto busca demostrar que hace falta.
Descripción	"Shadow AI": uso de modelos, aplicaciones o servicios de IA por parte de empleados sin conocimiento, aprobación o gobernanza del equipo de seguridad o TI de la organización.
Estadística principal	81% de los empleados usa herramientas de IA no aprobadas en su trabajo (88% entre los propios profesionales de seguridad); la proporción de datos corporativos compartidos con IA que son sensibles se triplicó de 10,7% en 2023 a 34,8% en 2025.
Empresas afectadas / muestra	UpGuard: dos encuestas de 2024 a 1.500 líderes de seguridad y empleados en EE. UU., Reino Unido, Canadá, Australia, Nueva Zelanda, Singapur e India. Cyberhaven: análisis de telemetría real (no encuesta) sobre el tráfico de datos corporativos hacia herramientas de IA generativa, agregado a nivel de mercado.
Impacto económico / empresarial	En promedio, una empresa registra 223 incidentes mensuales de envío de datos sensibles a aplicaciones de IA (el doble que hace un año); 27% de las organizaciones reporta que más del 30% de los datos que procesa su IA contiene información privada (registros de clientes, datos financieros, secretos comerciales).
Sectores / industrias afectadas	Transversal; el tráfico web global hacia sitios de IA generativa creció 50% entre febrero de 2024 y enero de 2025 (de 7.000 a 10.530 millones de visitas mensuales), según telemetría empresarial de Menlo Security.
Quién reporta el problema	UpGuard (empresa de gestión de riesgo de terceros); Cyberhaven (empresa de prevención de pérdida de datos); Menlo Security (empresa de seguridad web) — las tres son proveedores con interés comercial directo en vender herramientas de monitoreo de shadow AI.
Metodología	UpGuard: encuesta cuantitativa a 1.500 personas. Cyberhaven: análisis observacional de telemetría de tráfico de datos real en clientes corporativos (no es una encuesta de opinión, sino medición directa de tráfico, aunque limitada a los clientes de Cyberhaven). Menlo Security: análisis de tráfico web agregado.

Año de los datos	2024-2025 (UpGuard, State of Shadow AI Report 2025); 2023-2025 (Cyberhaven, AI Adoption and Risk Report 2025).
País / región	Global, con concentración de la muestra en EE. UU., Reino Unido y otros países angloparlantes (UpGuard).
Fuente original	UpGuard — "State of Shadow AI Report 2025"; Cyberhaven — "AI Adoption and Risk Report 2025".
Enlace a la fuente	https://www.upguard.com/blog/state-of-shadow-ai
Referencia bibliográfica completa	UpGuard, Inc. (2025). State of Shadow AI Report 2025. Mountain View, CA, Estados Unidos: UpGuard, Inc. Cyberhaven, Inc. (2025). AI Adoption and Risk Report 2025. Palo Alto, CA, Estados Unidos: Cyberhaven, Inc.
Limitaciones o sesgos	La muestra de UpGuard está sesgada hacia países angloparlantes desarrollados, con posible menor representación de PyMEs y de mercados no anglosajones. Cyberhaven y UpGuard son proveedores de software de seguridad con interés directo en documentar (y luego vender solución a) este riesgo, lo que constituye un conflicto de interés relevante a señalar, aunque su telemetría de tráfico real es más difícil de sesgar que una encuesta de opinión pura.

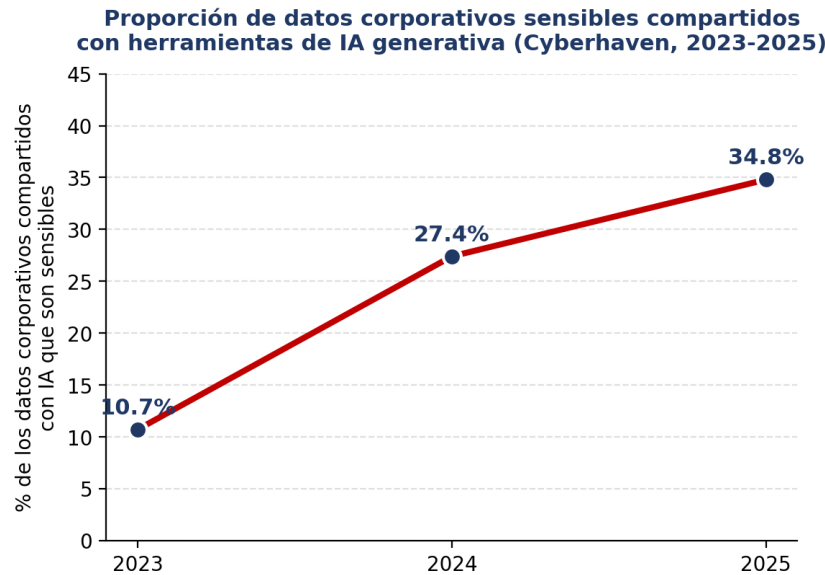


Figura 5. Evolución del porcentaje de datos corporativos sensibles compartidos con IA generativa. Fuente: Cyberhaven (2023-2025).

2.6 Control de acceso roto (broken access control) como causa raíz transversal

Problema o riesgo	El control de acceso deficiente o ausente —la falla exacta que el proyecto rag-exfiltration-backend demuestra deliberadamente en su Avance 1 al no filtrar por rol o clasificación en la recuperación— es la categoría de vulnerabilidad más común y más crítica tanto en aplicaciones web tradicionales como en sistemas de IA.
Descripción	Fallas que permiten a un usuario (o a un modelo de IA actuando en su nombre) acceder a datos o funciones para los que no tiene autorización, ya sea por ausencia de verificación, verificación incompleta o verificación que ocurre en el lugar equivocado del flujo de datos.
Estadística principal	El control de acceso roto es la categoría #1 del OWASP Top 10 de aplicaciones web (la clasificación de referencia de la industria) desde su edición 2021, y OWASP identifica explícitamente que las arquitecturas RAG heredan este mismo riesgo cuando no aplican

	control de acceso a nivel de recuperación, tal como advierte el propio marco OWASP Top 10 para LLM 2025 respecto a bases de datos vectoriales multiusuario.
Empresas / sistemas afectados	Aplicable a cualquier sistema —tradicional o basado en IA— que gestione datos con distintos niveles de sensibilidad o distintos roles de usuario; el propio marco OWASP LLM advierte específicamente sobre bases de datos vectoriales multiusuario (multi-tenant) sin partición ni control de acceso adecuados.
Impacto medible	El estudio académico "SoK: Privacy Risks and Mitigations in Retrieval-Augmented Generation Systems" documenta que la ausencia de control de acceso interno permite que empleados sin necesidad de conocer cierta información tengan, de hecho, acceso ilimitado a todos los documentos almacenados en el sistema RAG, incluyendo aquellos indexados por error con datos personales no depurados.
Sectores / dominios afectados	Transversal a toda arquitectura de software; particularmente crítico en RAG empresariales que combinan documentos de distinta clasificación (público, interno, confidencial, secreto) en un mismo almacén vectorial, exactamente el escenario modelado en el corpus del proyecto rag-exfiltration-backend (carpetas público/interno/confidencial/secreto).
Quién reporta el problema	OWASP (Open Worldwide Application Security Project), organización sin fines de lucro dedicada a la seguridad de aplicaciones, junto con el OWASP GenAI Security Project específico para LLM.
Metodología	El OWASP Top 10 se construye mediante consenso de la comunidad de seguridad —cientos de profesionales, datos de programas de recompensa por errores (bug bounty) y análisis de incidentes reales reportados— y se actualiza cada 3-4 años (última edición web: 2021; última edición LLM: 2025).
Año de los datos	2021 (OWASP Top 10 web, vigente) y 2025 (OWASP Top 10 for LLM Applications).
País / región	Global (marco de referencia internacional, sin recorte geográfico).
Fuente original	OWASP Foundation — "OWASP Top 10 for LLM Applications 2025" y "OWASP Top 10:2021 — Web Application Security Risks".
Enlace a la fuente	https://owasp.org/www-project-top-10-for-large-language-model-applications/
Referencia bibliográfica completa	OWASP Foundation. (2025). OWASP Top 10 for LLM Applications 2025. OWASP GenAI Security Project. OWASP Foundation. (2021). OWASP Top 10:2021 — The Ten Most Critical Web Application Security Risks.
Limitaciones o sesgos	El OWASP Top 10 es un marco de consenso cualitativo (qué riesgos importan más), no una medición estadística cuantitativa de incidencia poblacional; el orden de las categorías refleja la severidad y frecuencia percibida por la comunidad experta, no un porcentaje medido de empresas afectadas. Es, sin embargo, la fuente de menor sesgo comercial de todo este informe, al ser una organización sin ánimo de lucro sin producto propio que vender.

2.7 Brecha entre la adopción acelerada de IA y la inversión en su gobernanza/seguridad

Problema o riesgo	Las organizaciones adoptan IA generativa y sistemas RAG mucho más rápido de lo que despliegan controles de seguridad y gobernanza para ellos, generando una "deuda de seguridad" acumulada — el mismo desfase temporal que separa el Avance 1 (vulnerable) del Avance 2 (con filtrado) del proyecto de origen.
Descripción	Diferencia entre la velocidad de despliegue de nuevas capacidades de IA en producción y la velocidad de implementación de controles de acceso, auditoría, clasificación de datos y políticas correspondientes.

Estadística principal	69% de las organizaciones sospecha o tiene evidencia de que su personal usa IA generativa pública prohibida (Gartner, 2025); en paralelo, 92% del uso de IA generativa empresarial se concentra en una sola herramienta de consumo masivo (ChatGPT), fuera de los canales gobernados por TI (LayerX, 2025).
Empresas afectadas / muestra	Encuestas de Gartner a clientes empresariales (metodología propietaria no siempre publicada en detalle) y de LayerX ("Enterprise AI and SaaS Data Security Report 2025", basado en telemetría de navegador real en organizaciones clientes, no solo encuesta de opinión).
Impacto económico / empresarial	IBM estima que las organizaciones con alto uso de shadow AI y sin controles de gobernanza incurrir en un costo adicional de USD 670.000 por brecha frente a organizaciones con gobernanza adecuada (ver problema 3), lo que cuantifica directamente el costo de esta brecha entre adopción y gobernanza.
Sectores / industrias afectadas	Transversal; especialmente pronunciado en organizaciones que integran IA generativa en productos existentes sin anunciarlo claramente a los usuarios finales, según Gartner.
Quién reporta el problema	Gartner, Inc. (firma de investigación, menor conflicto de interés directo); LayerX (proveedor de seguridad para navegadores, con interés comercial); IBM/Ponemon Institute.
Metodología	Gartner: encuesta a clientes empresariales dentro de su base de suscriptores (metodología de muestreo no aleatorio, ya que solo incluye organizaciones que ya son clientes de Gartner). LayerX: telemetría de extensión de navegador desplegada en organizaciones clientes reales, lo que mide comportamiento efectivo en lugar de percepción autorreportada.
Año de los datos	2025.
País / región	Global, con la limitación de que las muestras de Gartner y LayerX provienen de sus respectivas bases de clientes, no de la población empresarial general.
Fuente original	Gartner, Inc. — encuesta citada en "Top 50 Shadow AI Statistics 2026" (Second Talent, compilador secundario; dato original de Gartner no publicado en un informe de acceso público verificado de forma independiente para este informe).
Enlace a la fuente	https://www.gartner.com/en/newsroom
Referencia bibliográfica completa	Gartner, Inc. (2025). Encuesta sobre uso de GenAI no autorizada [dato citado por fuentes secundarias]. Stamford, CT, Estados Unidos: Gartner, Inc.
Limitaciones o sesgos	La cifra del 69% de Gartner se identificó únicamente a través de una fuente secundaria (agregador) y no se pudo verificar directamente en un informe primario de Gartner de acceso público durante esta investigación — se señala explícitamente como una limitación siguiendo el criterio de no presentar cifras no verificables como si tuvieran el mismo respaldo que las demás. Las cifras de LayerX y Gartner miden comportamiento dentro de sus respectivas bases de clientes, no una muestra representativa de todas las empresas.

3. Tabla de probabilidades de éxito de ataque y exposición

La siguiente tabla reúne, en formato de probabilidad/tasa medida, todos los valores cuantitativos localizados en la investigación, ordenados de lo más específico al ataque RAG (filas 1-5, evidencia experimental directa) a lo más general del ecosistema empresarial de IA (filas 6-12, evidencia de encuesta/telemetría). Ninguna de estas cifras debe interpretarse como "la probabilidad de que le ocurra a cualquier empresa": cada una está condicionada a la población específica descrita en la columna "Nota".

Evento / métrica medida	Valor	Nota	Fuente
Extracción de datos mediante inyección de instrucciones en un GPT/RAG de producción (n=25 sistemas)	100%	Éxito del ataque logrado con 1-2 consultas por sistema	Qi et al., 2024 (Harvard/CMU/MBZUAI)
Reconstrucción verbatim de un corpus pequeño (77.000 palabras) con 100 consultas	41,73%	Proporción del texto original recuperada	Qi et al., 2024
Reconstrucción verbatim de un corpus grande (1.569.000 palabras) con 100 consultas	3,22%	Proporción del texto original recuperada	Qi et al., 2024
Tasa de reconstrucción de un RAG sin ninguna mitigación (modelo Llama3-8B)	88,9%	Línea base experimental	Qi et al., 2024
Tasa de reconstrucción con mitigación combinada (prompt de seguridad + PINE)	52,3%	Reducción de ~37 puntos porcentuales vs. línea base	Qi et al., 2024
Organizaciones que sufrieron una brecha de su modelo/aplicación de IA en el último año	13%	Sobre 600 organizaciones ya afectadas por brechas	IBM Cost of a Data Breach Report, 2025
Brechas de IA en las que faltaban controles de acceso adecuados	97%	Condicional a que ya hubo brecha de IA	IBM, 2025
Brechas totales vinculadas a "shadow AI" (IA no gobernada)	20%	1 de cada 5 brechas registradas	IBM, 2025
Organizaciones sin política de gobernanza de IA	63%	Sobre 600 organizaciones encuestadas	IBM, 2025
Empleados que usan herramientas de IA no aprobadas por su organización	81%	88% entre profesionales de seguridad	UpGuard, 2025
Datos corporativos compartidos con IA que son sensibles (2025 vs. 10,7% en 2023)	34,8%	Triplicado en dos años	Cyberhaven, 2025
Brechas de IA por mal uso transfronterizo de GenAI, proyección a 2027	>40%	Predicción de analista, no medición retrospectiva	Gartner, 2025

4. Tabla comparativa de los siete problemas

Problema	Estadística principal	Año	Región	Fuente	Calidad de la evidencia
Inyección de instrucciones (extracción de RAG)	100% de éxito en 25 sistemas RAG de producción	2024	N/A (laboratorio)	Harvard / CMU / MBZUAI	Alta (estudio académico revisado por pares)
Escalamiento con tamaño de corpus	41,7% extraído de corpus pequeño vs. 3,2% de corpus grande	2024	N/A (laboratorio)	Qi et al. (arXiv)	Alta (experimento controlado y reproducible)
Brechas ligadas a IA / falta de control de acceso	13% de orgs con brecha de IA; 97% sin control de acceso	2025	17 países	IBM / Ponemon Institute	Alta (n=600, 20 años de serie histórica)
Ausencia de gobernanza de IA	63% sin política de gobernanza de IA	2025-2027	Global	IBM / Gartner	Alta (IBM) / Media (proyección Gartner)
Shadow AI: fuga de datos por empleados	81% usa IA no aprobada; datos sensibles compartidos +225% en 2 años	2023-2025	EE. UU., UK y otros	UpGuard / Cyberhaven	Media-alta (proveedores comerciales, telemetría real)

Problema	Estadística principal	Año	Región	Fuente	Calidad de la evidencia
Control de acceso roto (causa raíz)	Categoría #1 del OWASP Top 10 desde 2021	2021-2025	Global (marco)	OWASP Foundation	Alta (consenso de industria, sin ánimo de lucro)
Brecha adopción vs. gobernanza de IA	69% de orgs sospecha uso de GenAI prohibida	2025	Base de clientes Gartner	Gartner / LayerX	Media (cifra no verificada en fuente primaria)

5. Síntesis: calidad de la evidencia, impacto cuantificable y vacíos de información

5.1 Problemas con mayor evidencia estadística disponible

La evidencia más sólida de todo el informe es el estudio de Qi et al. (2024): a diferencia de una encuesta, mide directamente —con métricas reproducibles (ROUGE-L, BLEU, F1, BERTScore)— cuánto contenido privado logra extraerse de un RAG real bajo ataque, con un diseño experimental controlado y variables aisladas (tamaño de corpus, número de consultas, tamaño de fragmento). Es, con diferencia, la fuente con menor sesgo comercial y mayor rigor metodológico de este informe.

5.2 Problemas con mayor impacto económico cuantificable

El costo adicional de USD 670.000 por brecha ligada a shadow AI (IBM, 2025) es la cifra económica más sólida, al provenir de un costeo contable real sobre 600 organizaciones efectivamente afectadas, no de una proyección. La cifra de Gartner ("más del 40% de las brechas de IA para 2027") es, en cambio, una predicción de analista y debe tratarse con ese nivel de certeza menor.

5.3 Problemas con mayores vacíos de información

El mayor vacío es la ausencia de estudios que midan la tasa de éxito de estos ataques específicamente en sistemas RAG empresariales en producción (fuera del laboratorio) — el estudio de Harvard/CMU es, hasta donde permitió verificar esta investigación, el más citado y riguroso, pero es uno solo, sin réplica independiente publicada todavía. La cifra del 69% de Gartner sobre uso sospechado de GenAI prohibida tampoco pudo verificarse en una fuente primaria de acceso público, por lo que se presenta con esa salvedad explícita.

5.4 Relación directa con el proyecto rag-exfiltration-backend

Los siete problemas documentados corresponden, punto por punto, a las decisiones de diseño del proyecto de origen: el Avance 1 (sin filtrado) ilustra exactamente el problema 6 (control de acceso roto) y el problema 3 (ausencia de controles de acceso en el 97% de las brechas de IA); el Ataque 3 (inyección de instrucciones) ilustra exactamente el problema 1, con una tasa de éxito empírica del 100% en el estudio académico citado; y el corpus reducido de 5 documentos usado en las demos ilustra directamente el hallazgo del problema 2 sobre mayor extraíble en corpus pequeños.

6. Referencias bibliográficas completas (con enlaces activos)

- [Qi, Z., Zhang, H., Xing, E., Kakade, S., & Lakkaraju, H. \(2024\). Follow My Instruction and Spill the Beans: Scalable Data Extraction from Retrieval-Augmented Generation Systems. arXiv:2402.17840.](#)

- [IBM Security & Ponemon Institute. \(2025\). Cost of a Data Breach Report 2025. Armonk, NY, Estados Unidos: IBM Corporation.](#)
- [OWASP Foundation. \(2025\). OWASP Top 10 for LLM Applications 2025. OWASP GenAI Security Project.](#)
- [OWASP Foundation. \(2021\). OWASP Top 10:2021 — The Ten Most Critical Web Application Security Risks.](#)
- [Gartner, Inc. \(2025\). Gartner Predicts 40% of AI Data Breaches Will Arise from Cross-Border GenAI Misuse by 2027 \[comunicado de prensa\]. Stamford, CT, Estados Unidos.](#)
- [UpGuard, Inc. \(2025\). State of Shadow AI Report 2025. Mountain View, CA, Estados Unidos: UpGuard, Inc.](#)
- [Vectra AI. \(2026\). Shadow AI Explained: Risks, Costs, and Enterprise Governance \[síntesis de datos de Cyberhaven, IBM y CybSafe/NCA\].](#)
- [Martinelli, I., & Ponti, M. A. \(2025\). Towards Secure Retrieval-Augmented Generation: Preventing LLM Data Leaks with RBAC. Anais do XXII Encontro Nacional de Inteligência Artificial e Computacional \(BRACIS\).](#)
- [SoK: Privacy Risks and Mitigations in Retrieval-Augmented Generation Systems \(2026\). arXiv:2601.03979.](#)

7. Nota final sobre el uso de este informe

Las cifras presentadas corresponden a fuentes verificadas al momento de la investigación (septiembre de 2026). La evidencia experimental (Qi et al., 2024) tiene el mayor rigor metodológico pero proviene de un entorno de laboratorio; las cifras de encuestas comerciales (IBM, UpGuard, Cyberhaven, Gartner) miden el ecosistema empresarial real pero con distintos niveles de sesgo de selección y de interés comercial, señalados explícitamente en cada ficha. Se recomienda citar siempre la fuente primaria (enlazada) antes que este resumen.